FOUNDATIONS

IAM – IDENTITY & ACCESS MANAGEMENT

FOUNDATIONS

IAAA



Identification

- ❑ Identify an entity: I am John
- ❑ Possible to identify yourself without authentication



Authentication

- ❑ Password, PIN, Biometric
- ❑ Authentication can only be done after identification
- ❑ Non-repudiation



Authorization

- ❑ Access Control Lists
- ❑ Clearances
- ❑ Authorization is consulted after authentication



Accountability

- ❑ Account audits
- ❑ Log reviews

Identification

- The process of claiming or providing an identity.
- **Example:** When a user enters a username on a website login page, they are identifying themselves to the system. The system now knows who the user claims to be, but hasn't verified the claim yet.
- **Analogy:** It's like introducing yourself to someone by saying your name. They know who you say you are, but they haven’t confirmed it yet.

Authentication

The process of verifying the user's identity.

Example: After entering a username, the user provides a password. The system checks whether the password matches the username to authenticate (verify) the user's identity.

Types of Authentication:

- Something you know: Password or PIN.
- Something you have: OTP via a mobile device or security token.
- Something you are: Fingerprint, facial recognition, etc.

Analogy: After you tell someone your name, they might ask to see your ID to verify that you are indeed the person you claim to be

IDENTIFICATION & AUTHENTICATION

- Identification - a subject *claims* an identity:
  - I am John Cooper
  - ID badge
  - Facing a camera for retina or face scan
- Authentication - a subject *proves* his identity:
  - Password
  - PIN Number of Credit Card

FOUNDATIONS

IDENTITY LIFECYCLE



PROVISIONING

- ❑ Create New Accounts
- ❑ Assign privileges (Authorization)



REVOCATION

- ❑ Disable accounts of employees who leave, retire, or are terminated

REVIEW

- ❑ Periodic account review
- ❑ Disable inactive accounts
- ❑ Audit privilege creep

FOUNDATIONS

AUTHENTICATION FACTORS



- Type I: something that you know:
  - Password
  - PIN
- Type II: something that you have:
  - Smart card
  - Mobile SIM
- Type III: something that you are:
  - Retina Pattern
  - Fingerprints



FOUNDATIONS

TYPE 1: SOMETHING YOU KNOW



- ✓ At least 8 characters long
- ✓ Should contain both uppercase and lowercase alphabets
- ✓ Should contain at least one numeric character
- ✓ Should contain at least one special character
- ✓ Passphrases - easy to remember & difficult to break: Ilik3$up3rman
- Should not contain common names e.g. cities or patterns: 123
- Should not be so complex that the user writes it down somewhere
- Should not have unreasonable requirements e.g. at least 12 characters

FOUNDATIONS

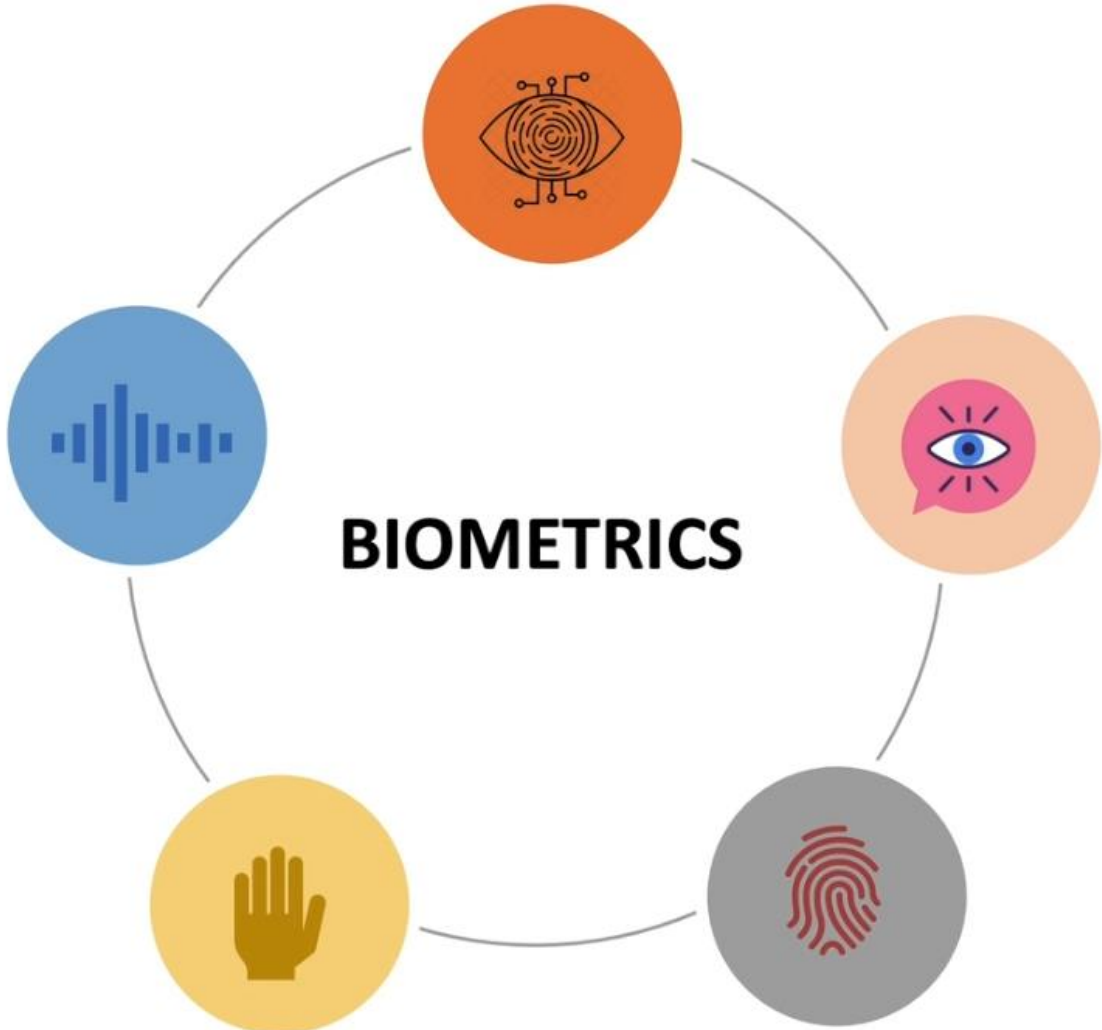
TYPE 2: SOMETHING YOU HAVE



- ❑ Identity Badge
- ❑ Smart Card
- ❑ Mobile SIM – receive SMS
- ❑ Authenticator app – Google Authenticator

TYPE 3: SOMETHING YOU ARE

BIOMETRICS



RETINA SCAN

Most accurate, can even identify identical twins

IRIS SCAN

Second most accurate biometric factor after retina scan

FINGERPRINTS

99.9% accurate if the test involves 4 or more fingers

PALM SCANS

Some palm vein scanners capture millions of data points, very accurate

VOICE PATTERN

Not as accurate others e.g. retina scans

FOUNDATIONS

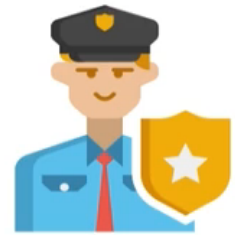
MULTIFACTOR AUTHENTICATION



- Single factor authentication e.g., passwords - weak
- MFA combines more than one type of authentication
- Often, Type I and Type II are combined
  - Type I: something that you know (Password)
  - Type II: something that you have (Mobile SIM, SMS)
- 2FA: Two Factors combined

FOUNDATIONS

AUTHORIZATION & ACCOUNTABILITY



- Authorization - decides who is allowed to perform what:
  - User – Can only view his account
  - Administrator – Can create, view and delete user accounts
  - If a user accesses a file, authorization is checked (e.g. read-only)
- Accountability - logging user activities for accountability:
  - Only after identification and authentication
  - Audits of logs and accounts to identify any violations

Authorization

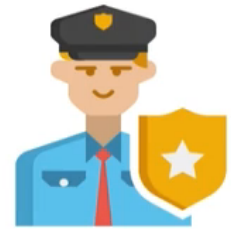
The process of determining what an authenticated user is allowed to do.

Example: After logging into a banking application, a customer can view their account balance but not the balances of other customers. The system grants access (authorization) only to the resources they are allowed to see or interact with.

Analogy: After verifying who you are, the bank teller will allow you to access only your own bank account but not someone else's.

FOUNDATIONS

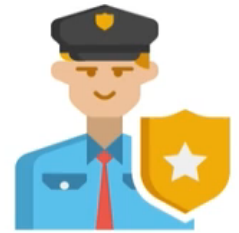
AUTHORIZATION



- Need to Know:
  - Give a subject the minimum data/info that he/she needs to complete their job
  - Give a subject the least privileges that he/she needs to complete her job duties
- Example:
  - An administrator may have almost universal access e.g. create, modify and delete user accounts but does not requires access to view employee salary information
  - A user may need to read data from a file for performing their job duties but only requires read-only access, should not be given read-write permissions

FOUNDATIONS

AUTHORIZATION: PRIVILEGE CREEP



- Happens when someone accumulates privileges over time as their roles change, but older privileges are not relinquished
- Example: A sales assistant moves on to become network administrator then security administrator but retains privileges to access sales systems despite lack of need

Accountability (or Audit)

The process of tracking user actions to ensure they can be held responsible for their activities.

Example: In a network system, every user action is logged—such as accessing a file, modifying settings, or deleting data. These logs are used for auditing purposes, ensuring that the user can be held accountable for any actions performed during their session.

Analogy: In a library, every book borrowed or returned is recorded. If a book goes missing, the records show who had it last, making them accountable for it.

FOUNDATIONS

ACCOUNTABILITY

- Holding people responsible for their actions
- Enforced through:
  - Log audits
  - Account audits
  - Job rotation
- Can only be enforced if we have non-repudiation i.e. subject must have done identification and authentication

FOUNDATIONS

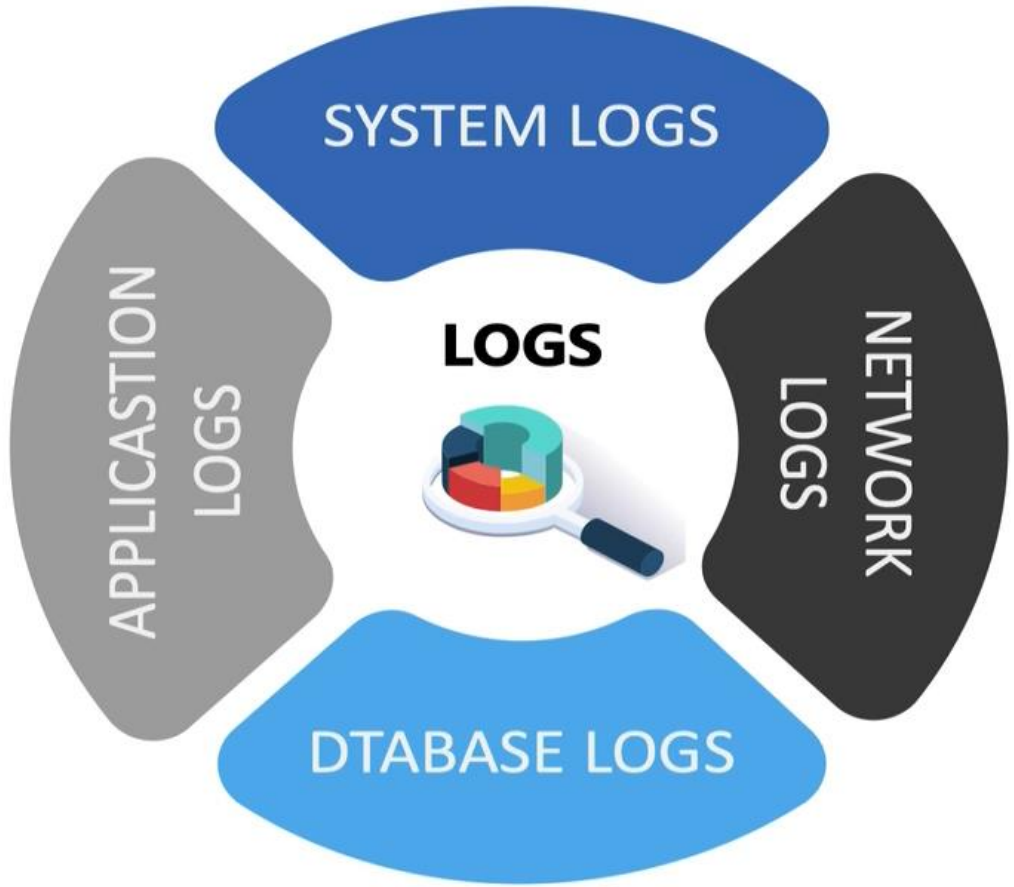
ACCOUNTABILITY

System Logs

- ❑ Resources used
- ❑ Applications executed

App Logs

- ❑ Exceptions
- ❑ Crashes
- ❑ Anomalies



Net Logs

- ❑ Routers, switches logs
- ❑ Firewall logs

DB Logs

- ❑ Queries executed
- ❑ Files accessed
- ❑ Modifications logged

Practical Scenario

Consider a company’s internal file-sharing system:

Identification: A user enters their employee ID.

Authentication: The system prompts them to enter a password or scan their fingerprint.

Authorization: After successfully logging in, the system determines the user can access certain project files but not sensitive HR data.

Accountability: Every file the user accesses is logged. If there’s a data breach, the system administrator can review the logs to see which user accessed or modified critical files.